



CLIENT READINESS INTAKE

SECURITY & READINESS SELF-ASSESSMENT

Assessment Method v1.0 | Document Rev. 2026.09

ORGANIZATION / HOUSEHOLD	PRIMARY CONTACT
EMAIL / PHONE	DATE COMPLETED

PURPOSE

This questionnaire establishes a structured, self-reported baseline before FlintWatch professional review. Answer each control based on how your organization operates today - not how you intend to operate later.

01 SELF-ASSESS Complete all 24 controls.	02 FLINTWATCH REVIEW Evidence and scores are reviewed.	03 VERIFIED REPORT Confirmed findings become actionable.
--	--	--

DO NOT ENTER SECRETS
Never provide passwords, recovery codes, private keys, API keys, Social Security numbers, payment-card numbers, or other authentication secrets in this questionnaire.

SCORING STANDARD

0	NOT IN PLACE No reliable control.	1	WEAK / AD HOC Inconsistent or informal.
2	PARTIAL Important gaps remain.	3	GOOD Substantially implemented.
4	STRONG Consistent and maintained.	N/A	NOT APPLICABLE Genuinely does not apply.

ASSESSMENT BOUNDARY

This is a self-reported readiness screening. FlintWatch may confirm, raise, lower, or exclude scores during professional review. It is not a penetration test, compliance certification, legal opinion, or security guarantee.



READINESS CONTROL GROUP

Identity & Access

Select one response for each control. Mark evidence as Yes, No, or Unsure. Use N/A only when the control genuinely does not apply.

01 IAM-01

How consistently does your organization use multi-factor authentication (MFA) for critical accounts such as email, banking, administrator, and cloud accounts?

MFA means a second factor beyond a password, such as an authenticator app, passkey, security key, or one-time code.

- | | |
|--|--|
| ☐ 0 MFA is generally not used on critical accounts. | ☐ 1 MFA is used on only a few accounts or is optional/inconsistent. |
| ☐ 2 MFA protects many important accounts, but meaningful gaps remain. | ☐ 3 MFA protects nearly all critical accounts and is normally required. |
| ☐ 4 MFA is required across critical accounts and stronger methods such as passkeys, security keys, or authenticator apps are preferred. | ☐ N/A This control does not apply to our environment. |

EVIDENCE ☐ Yes ☐ No ☐ Unsure NOTES _____

02 IAM-02

How well does your organization use unique, strong passwords and a password manager?

Consider business email, banking, cloud services, social media, vendor portals, and administrative accounts.

- | | |
|--|--|
| ☐ 0 Passwords are commonly reused, shared, weak, or stored insecurely. | ☐ 1 Some strong/unique passwords are used, but reuse or informal storage is still common. |
| ☐ 2 Many important accounts use unique passwords, but password-manager use or coverage is incomplete. | ☐ 3 A reputable password manager is used for nearly all important accounts with unique passwords. |
| ☐ 4 Password-manager use and unique credentials are standard practice, with periodic review of legacy/reused passwords. | ☐ N/A This control does not apply to our environment. |

EVIDENCE ☐ Yes ☐ No ☐ Unsure NOTES _____

03 IAM-03

How well protected and up to date are your account recovery methods?

Examples include recovery email/phone numbers, backup codes, trusted devices, emergency access, and recovery instructions.

- | | |
|---|--|
| ☐ 0 Recovery methods are unknown, outdated, inaccessible, or stored insecurely. | ☐ 1 Some recovery information exists, but it is scattered, outdated, or weakly protected. |
| ☐ 2 Most critical accounts have usable recovery methods, but documentation or protection is incomplete. | ☐ 3 Recovery methods are current, protected, and documented for nearly all critical accounts. |
| ☐ 4 Recovery methods are current, protected, periodically reviewed, and include a tested emergency recovery process. | ☐ N/A This control does not apply to our environment. |

EVIDENCE ☐ Yes ☐ No ☐ Unsure NOTES _____

04 IAM-04

How tightly is administrator or privileged access limited to people who actually need it?

Think about local computer administrators, cloud administrators, financial systems, routers, and other high-impact accounts.

- | | |
|--|---|
| ☐ 0 Administrator access is broadly shared or not understood. | ☐ 1 Some access limits exist, but routine users often have unnecessary administrator rights. |
| ☐ 2 Administrative access is partly restricted, but reviews or separation of duties are inconsistent. | ☐ 3 Administrative access is limited to appropriate people and standard accounts are normally used for routine work. |
| ☐ 4 Least privilege is consistently enforced, privileged access is reviewed, and elevated access is separated from routine use. | ☐ N/A This control does not apply to our environment. |

EVIDENCE ☐ Yes ☐ No ☐ Unsure NOTES _____



READINESS CONTROL GROUP

Device Security

Select one response for each control. Mark evidence as Yes, No, or Unsure. Use N/A only when the control genuinely does not apply.

05 DEV-01

How consistently are operating systems, browsers, applications, and device firmware kept current with security updates?

Include computers, phones, tablets, routers, security cameras, and other business technology.

- | | |
|--|--|
| ☐ 0 Updates are frequently delayed, disabled, or unknown. | ☐ 1 Some devices update, but there is no consistent process and outdated systems may remain. |
| ☐ 2 Most major systems are updated, but coverage or verification is incomplete. | ☐ 3 Automatic updates are enabled where practical and important systems are usually kept current. |
| ☐ 4 Update coverage is documented/reviewed and unsupported or exception devices are actively managed. | ☐ N/A This control does not apply to our environment. |

EVIDENCE ☐ Yes ☐ No ☐ Unsure NOTES _____

06 DEV-02

How consistently are endpoint protection and host firewalls enabled on business computers?

Examples include Microsoft Defender or another supported security product, Windows/macOS firewall, real-time protection, and tamper protection.

- | | |
|--|--|
| ☐ 0 Endpoint protection/firewalls are disabled, missing, or unknown on important systems. | ☐ 1 Some protection exists, but coverage or settings are inconsistent. |
| ☐ 2 Most computers have protection enabled, but verification or monitoring is incomplete. | ☐ 3 Supported endpoint protection and firewalls are enabled on nearly all business computers. |
| ☐ 4 Protection is consistently enabled, verified, monitored, and configured to resist unauthorized changes. | ☐ N/A This control does not apply to our environment. |

EVIDENCE ☐ Yes ☐ No ☐ Unsure NOTES _____

07 DEV-03

How consistently do business phones, laptops, and tablets use strong screen locks and device encryption?

Encryption protects data if a device is lost or stolen; examples include BitLocker, FileVault, and modern mobile-device encryption.

- | | |
|---|--|
| ☐ 0 Important devices are not reliably locked or encrypted. | ☐ 1 Some devices use locks/encryption, but coverage is inconsistent or unknown. |
| ☐ 2 Most devices are protected, but inventory or verification is incomplete. | ☐ 3 Nearly all business devices use appropriate screen locks and device encryption. |
| ☐ 4 Device protection is documented, verified, and consistently applied to all supported business devices. | ☐ N/A This control does not apply to our environment. |

EVIDENCE ☐ Yes ☐ No ☐ Unsure NOTES _____

08 DEV-04

How well does your organization remove or isolate unused, unsupported, or high-risk devices and applications?

Unsupported operating systems, abandoned software, old network devices, and unnecessary applications can increase risk.

- | | |
|---|--|
| ☐ 0 Unsupported or unnecessary technology is common and not tracked. | ☐ 1 Known old/high-risk technology exists with little formal cleanup. |
| ☐ 2 Some cleanup occurs, but device/software inventory or retirement is incomplete. | ☐ 3 Unsupported and unnecessary technology is normally removed or isolated when identified. |
| ☐ 4 A maintained inventory supports a consistent retirement, removal, and exception process. | ☐ N/A This control does not apply to our environment. |

EVIDENCE ☐ Yes ☐ No ☐ Unsure NOTES _____



READINESS CONTROL GROUP

Network & Wi-Fi

Select one response for each control. Mark evidence as Yes, No, or Unsure. Use N/A only when the control genuinely does not apply.

09 NET-01

How well secured is your primary business Wi-Fi and router/gateway administration?

Consider modern Wi-Fi encryption, unique Wi-Fi credentials, and non-default router/administrator credentials where configurable.

- | | |
|---|---|
| ☐ 0 Wi-Fi/router security is weak, open, default, or unknown. | ☐ 1 Basic protection exists, but default/shared credentials or outdated settings may remain. |
| ☐ 2 Modern encryption is likely in use, but credentials/settings have not been fully reviewed or hardened. | ☐ 3 Modern encryption and strong non-default credentials are used for business networking. |
| ☐ 4 Network security settings and credentials are hardened, documented, and periodically reviewed. | ☐ N/A This control does not apply to our environment. |

EVIDENCE ☐ Yes ☐ No ☐ Unsure NOTES _____

10 NET-02

How well maintained and protected is your internet router/firewall?

Consider firmware updates, remote administration, management access, and whether someone is responsible for checking the device.

- | | |
|--|--|
| ☐ 0 Firmware/management security is unknown or clearly outdated/exposed. | ☐ 1 Some maintenance occurs, but firmware or remote administration is not reliably controlled. |
| ☐ 2 The gateway is usually updated, but verification/documentation is incomplete. | ☐ 3 Firmware is current/managed and remote administration is disabled unless specifically required. |
| ☐ 4 Edge-device updates, management access, and configuration are documented and periodically reviewed. | ☐ N/A This control does not apply to our environment. |

EVIDENCE ☐ Yes ☐ No ☐ Unsure NOTES _____

11 NET-03

How well are guest, IoT, or untrusted devices separated from sensitive business systems?

Examples include guest Wi-Fi, smart TVs, cameras, speakers, personal devices, and other connected equipment.

- | | |
|--|---|
| ☐ 0 Business systems and guest/IoT/untrusted devices share the same network without meaningful separation. | ☐ 1 Some devices are separated, but most still share access to the same network. |
| ☐ 2 Partial separation exists, but sensitive systems are not consistently isolated. | ☐ 3 Guest/IoT devices are generally separated from sensitive business systems. |
| ☐ 4 Network segmentation is intentionally designed, documented, and maintained according to device trust/sensitivity. | ☐ N/A This control does not apply to our environment. |

EVIDENCE ☐ Yes ☐ No ☐ Unsure NOTES _____

12 NET-04

How well does your organization know and control services that are exposed directly to the internet?

Examples include port forwards, remote desktop, cameras, self-hosted servers, VPN gateways, and management interfaces.

- | | |
|--|--|
| ☐ 0 Internet-facing services/port forwards are unknown or unmanaged. | ☐ 1 Some exposure is known, but there is no complete review or justification. |
| ☐ 2 Most exposure is understood, but documentation or periodic review is incomplete. | ☐ 3 Internet-facing services are known, justified, and minimized. |
| ☐ 4 Exposure is documented, periodically reviewed, and unnecessary services are promptly removed. | ☐ N/A This control does not apply to our environment. |

EVIDENCE ☐ Yes ☐ No ☐ Unsure NOTES _____



READINESS CONTROL GROUP

Data & Backups

Select one response for each control. Mark evidence as Yes, No, or Unsure. Use N/A only when the control genuinely does not apply.

13 DATA-01

How consistently is important business data backed up on a defined schedule?

Consider accounting records, contracts, client records, business documents, email exports, configurations, and other data needed to operate.

- | | |
|--|---|
| ☐ 0 Important business data is not backed up. | ☐ 1 Backups happen occasionally or manually without a dependable schedule. |
| ☐ 2 Some critical data is backed up regularly, but coverage or monitoring is incomplete. | ☐ 3 Important data is backed up on a defined, generally reliable schedule. |
| ☐ 4 Backup coverage, schedule, success/failure status, and ownership are documented and routinely reviewed. | ☐ N/A This control does not apply to our environment. |

EVIDENCE ☐ Yes ☐ No ☐ Unsure NOTES _____

14 DATA-02

Do you maintain at least one backup copy that is protected from ransomware or loss of the primary systems?

Examples include an offline drive, immutable backup, disconnected copy, protected cloud versioning, or another isolated copy.

- | | |
|---|--|
| ☐ 0 No protected offline/isolated/immutable backup exists. | ☐ 1 A secondary copy exists sometimes, but it is usually connected or not reliably protected. |
| ☐ 2 Some important data has a protected copy, but coverage or process is incomplete. | ☐ 3 At least one important backup copy is appropriately isolated or otherwise ransomware-resistant. |
| ☐ 4 A documented multi-copy strategy includes protected/offline/immutable copies and is maintained consistently. | ☐ N/A This control does not apply to our environment. |

EVIDENCE ☐ Yes ☐ No ☐ Unsure NOTES _____

15 DATA-03

How recently has your organization tested restoring data from backup?

A successful backup is not proven until files or systems can actually be restored.

- | | |
|---|---|
| ☐ 0 No restore test has been performed or nobody knows whether restoration works. | ☐ 1 A restore has been attempted informally or a long time ago, but the process is not dependable. |
| ☐ 2 Some restore testing has occurred, but it is incomplete or undocumented. | ☐ 3 Backup restoration has been successfully tested and the recovery process is understood. |
| ☐ 4 Restore testing is scheduled/documented and recovery objectives, responsibilities, and lessons learned are maintained. | ☐ N/A This control does not apply to our environment. |

EVIDENCE ☐ Yes ☐ No ☐ Unsure NOTES _____

16 DATA-04

How well are sensitive business files and important records protected against unauthorized access?

Consider encryption, device security, access permissions, separate storage, and limiting who can reach financial/client/legal records.

- | | |
|--|---|
| ☐ 0 Sensitive files are broadly accessible or stored without meaningful protection. | ☐ 1 Some protection exists, but sensitive records are mixed with ordinary files or access is overly broad. |
| ☐ 2 Important records have some encryption/access control, but organization and coverage are incomplete. | ☐ 3 Sensitive records are appropriately encrypted/protected and access is generally limited by need. |
| ☐ 4 Sensitive-data handling, access control, storage, and retention are documented and periodically reviewed. | ☐ N/A This control does not apply to our environment. |

EVIDENCE ☐ Yes ☐ No ☐ Unsure NOTES _____



READINESS CONTROL GROUP

Fraud & Social Engineering

Select one response for each control. Mark evidence as Yes, No, or Unsure. Use N/A only when the control genuinely does not apply.

17 SOC-01

How prepared are staff/users to recognize and independently verify phishing, impersonation, and urgent-payment requests?

A strong process verifies suspicious requests using a separate trusted channel rather than replying or clicking the supplied link.

- | | |
|--|--|
| ☐ 0 There is no consistent awareness or verification practice. | ☐ 1 People know phishing is a risk, but verification depends on individual judgment. |
| ☐ 2 Some guidance/training exists, but it is not consistently applied. | ☐ 3 Users generally recognize suspicious requests and verify them through trusted channels. |
| ☐ 4 Awareness, verification procedures, and periodic training/testing are established and reinforced. | ☐ N/A This control does not apply to our environment. |

EVIDENCE ☐ Yes ☐ No ☐ Unsure NOTES _____

18 SOC-02

How strong is your verification process for payments, banking changes, credential requests, or other high-risk account changes?

Examples include callback verification using a known number, dual approval, in-person confirmation, or trusted vendor records.

- | | |
|--|---|
| ☐ 0 High-risk requests may be acted on without independent verification. | ☐ 1 Verification happens sometimes but depends on the individual or situation. |
| ☐ 2 A process exists for some high-risk requests, but coverage or enforcement is incomplete. | ☐ 3 High-risk financial/account changes normally require independent verification. |
| ☐ 4 Verification and approval rules are documented, consistently enforced, and periodically reviewed. | ☐ N/A This control does not apply to our environment. |

EVIDENCE ☐ Yes ☐ No ☐ Unsure NOTES _____

19 SOC-03

How regularly does your organization review and minimize sensitive information exposed publicly?

Consider social media, company websites, business listings, data brokers, domain records, employee information, and public documents.

- | | |
|--|---|
| ☐ 0 Public exposure has not been reviewed. | ☐ 1 Occasional cleanup occurs, but there is no repeatable review process. |
| ☐ 2 Some public sources are reviewed, but coverage/frequency is incomplete. | ☐ 3 Public information is periodically reviewed and unnecessary exposure is reduced. |
| ☐ 4 A scheduled exposure-review process covers key public sources and tracks remediation. | ☐ N/A This control does not apply to our environment. |

EVIDENCE ☐ Yes ☐ No ☐ Unsure NOTES _____

20 SOC-04

How clear is the process for reporting and responding to suspicious messages, calls, transactions, or account activity?

Consider who staff/contactors should notify, what evidence to preserve, and how urgent situations are escalated.

- | | |
|--|---|
| ☐ 0 There is no defined reporting or escalation process. | ☐ 1 People generally know who to tell, but the process is informal and undocumented. |
| ☐ 2 A partial process exists, but escalation, evidence preservation, or responsibilities are unclear. | ☐ 3 A clear reporting/escalation process is understood and generally followed. |
| ☐ 4 The process is documented, tested/trained, and linked to incident/fraud-response procedures. | ☐ N/A This control does not apply to our environment. |

EVIDENCE ☐ Yes ☐ No ☐ Unsure NOTES _____



READINESS CONTROL GROUP

Preparedness & Continuity

Select one response for each control. Mark evidence as Yes, No, or Unsure. Use N/A only when the control genuinely does not apply.

21 BCP-01

Can your organization access critical contacts and essential business records during an internet, cloud, or primary-device outage?

Do not place passwords or recovery codes in this questionnaire. Think only about whether protected alternate/offline access exists.

- | | |
|---|---|
| ☐ 0 Critical information is available only through the normal online/primary-device environment. | ☐ 1 A few records are available elsewhere, but continuity access is incomplete or outdated. |
| ☐ 2 Many essential records have alternate access, but important gaps remain. | ☐ 3 Critical contacts/records have protected alternate or offline access for most realistic outages. |
| ☐ 4 Continuity copies are protected, documented, maintained, and periodically tested. | ☐ N/A This control does not apply to our environment. |

EVIDENCE ☐ Yes ☐ No ☐ Unsure NOTES _____

22 BCP-02

How prepared is your organization to continue minimum operations during internet, power, or device outages?

Consider alternate internet, backup power, secondary devices, offline procedures, communications, and manual workarounds.

- | | |
|---|--|
| ☐ 0 No practical outage plan exists. | ☐ 1 Some improvised alternatives exist, but they are not organized or dependable. |
| ☐ 2 A partial continuity plan exists for some outage scenarios. | ☐ 3 Minimum operations and practical alternatives are defined for major outage scenarios. |
| ☐ 4 Continuity procedures, equipment, roles, and recovery steps are documented and periodically exercised. | ☐ N/A This control does not apply to our environment. |

EVIDENCE ☐ Yes ☐ No ☐ Unsure NOTES _____

23 BCP-03

How complete is your written cyber incident response checklist or plan?

A practical checklist should address immediate containment, who to contact, evidence preservation, account/device actions, notification, and recovery.

- | | |
|--|--|
| ☐ 0 No written cyber incident response checklist exists. | ☐ 1 People have an idea of what to do, but the process is mostly in someone's head. |
| ☐ 2 A partial checklist/plan exists, but important steps, roles, or contacts are missing. | ☐ 3 A practical written checklist covers containment, notification, evidence, and recovery. |
| ☐ 4 The incident plan is maintained, assigned, exercised, and improved after tests/incidents. | ☐ N/A This control does not apply to our environment. |

EVIDENCE ☐ Yes ☐ No ☐ Unsure NOTES _____

24 BCP-04

How consistently are important security improvements assigned to an owner, given a target date, and tracked through completion?

Consider audit findings, assessment recommendations, overdue security work, policy updates, and remediation projects.

- | | |
|--|---|
| ☐ 0 Security improvements are not formally tracked. | ☐ 1 Some items are remembered or listed, but ownership/deadlines are inconsistent. |
| ☐ 2 Important improvements are often tracked, but follow-through or closure verification is incomplete. | ☐ 3 Material security improvements are assigned, dated, and tracked to completion. |
| ☐ 4 A repeatable remediation process includes ownership, prioritization, due dates, closure evidence, and reassessment. | ☐ N/A This control does not apply to our environment. |

EVIDENCE ☐ Yes ☐ No ☐ Unsure NOTES _____



FLINTWATCH DEFENSE GROUP

SUBMISSION & FLINTWATCH REVIEW

Self-reported results remain unverified until professional review

FINAL

CLIENT CONFIRMATION

☐ I confirm these answers are provided in good faith and reflect my current understanding of our environment. I understand FlintWatch may confirm, raise, lower, or exclude individual control scores after review.

Client / Authorized Representative: _____ Date: _____

WHAT HAPPENS NEXT

SELF-REPORT	PROFESSIONAL REVIEW	VERIFIED ASSESSMENT
Your original responses remain preserved.	FlintWatch reviews evidence and adjusts only when support exists.	Final findings, recommendations, and remediation priorities are issued.

FLINTWATCH USE ONLY - RESULTS & REVIEW

CATEGORY	SELF-REPORTED	VERIFIED
Identity & Access	___ / 100	___ / 100
Device Security	___ / 100	___ / 100
Network & Wi-Fi	___ / 100	___ / 100
Data & Backups	___ / 100	___ / 100
Fraud & Social Engineering	___ / 100	___ / 100
Preparedness & Continuity	___ / 100	___ / 100
OVERALL READINESS	___ / 100	___ / 100

REVIEW STATUS

☐ Self-Reported / Unverified ☐ Review In Progress ☐ Verified Assessment Complete

FlintWatch Assessor: _____ Review Date: _____

Assessment Code: _____ Questionnaire Code: _____

REVIEWER NOTES

OFFICIAL SCORING

FlintWatch HQ calculates the official weighted 0-100 result using the current assessment methodology. The paper worksheet supports intake and review; it is not the authoritative scoring engine.